INTERNATIONAL STANDARD

ISO 31000

Second edition
2018-02

Risk management — Guidelines

Management du risque — Lignes directrices

iTeh STANDARD PREVIEW
(standards.iteh.ai)

ISO 31000:2018
https://standards.iteh.ai/catalog/standards/sist/aac269d2-3e9b-4fd1-b678-1df56c39129d/iso-31000-2018

Reference number
ISO 31000:2018(E)

© ISO 2018

iTeh STANDARD PREVIEW
(standards.iteh.ai)

ISO 31000:2018
https://standards.iteh.ai/catalog/standards/sist/aac269d2-3e9b-4fd1-b678-1df56c39129d/iso-31000-2018

COPYRIGHT PROTECTED DOCUMENT

© ISO 2018

All rights reserved. Unless otherwise specified, or required in the context of its implementation, no part of this publication may be reproduced or utilized otherwise in any form or by any means, electronic or mechanical, including photocopying, or posting on the internet or an intranet, without prior written permission. Permission can be requested from either ISO at the address below or ISO's member body in the country of the requester.

ISO copyright office
CP 401 • Ch. de Blandonnet 8
CH-1214 Vernier, Geneva
Phone: +41 22 749 01 11
Fax: +41 22 749 09 47
Email: copyright@iso.org
Website: www.iso.org

Published in Switzerland

Contents

Page

Foreword ... **iv**
Introduction ... **v**
1 Scope ... **1**
2 Normative references ... **1**
3 Terms and definitions ... **1**
4 Principles ... **2**
5 Framework ... **4**
5.1 General ... 4
5.2 Leadership and commitment ... 5
5.3 Integration ... 5
5.4 Design ... 6
5.4.1 Understanding the organization and its context ... 6
5.4.2 Articulating risk management commitment ... 6
5.4.3 Assigning organizational roles, authorities, responsibilities and accountabilities 7
5.4.4 Allocating resources ... 7
5.4.5 Establishing communication and consultation ... 7
5.5 Implementation ... 7
5.6 Evaluation ... 8
5.7 Improvement ... 8
5.7.1 Adapting ... 8
5.7.2 Continually improving ... 8
6 Process ... **8**
6.1 General ... 8
6.2 Communication and consultation ... 9
6.3 Scope, context and criteria ... 10
6.3.1 General ... 10
6.3.2 Defining the scope ... 10
6.3.3 External and internal context ... 10
6.3.4 Defining risk criteria ... 10
6.4 Risk assessment ... 11
6.4.1 General ... 11
6.4.2 Risk identification ... 11
6.4.3 Risk analysis ... 12
6.4.4 Risk evaluation ... 12
6.5 Risk treatment ... 13
6.5.1 General ... 13
6.5.2 Selection of risk treatment options ... 13
6.5.3 Preparing and implementing risk treatment plans ... 14
6.6 Monitoring and review ... 14
6.7 Recording and reporting ... 14
Bibliography ... **16**

iTeh STANDARD PREVIEW
(standards.iteh.ai)
ISO 31000:2018
https://standards.iteh.ai/catalog/standards/sist/aac269d2-3e9b-4fd1-b678-1ab0e39129d/iso-31000-2018

Risk management — Guidelines

1 Scope

This document provides guidelines on managing risk faced by organizations. The application of these guidelines can be customized to any organization and its context.

This document provides a common approach to managing any type of risk and is not industry or sector specific.

This document can be used throughout the life of the organization and can be applied to any activity, including decision-making at all levels.

2 Normative references

There are no normative references in this document.

3 Terms and definitions

For the purposes of this document, the following terms and definitions apply.

iTeh STANDARD PREVIEW
(standards.iteh.ai)

ISO and IEC maintain terminological databases for use in standardization at the following addresses:

— ISO Online browsing platform: available at http://www.iso.org/obp

— IEC Electropedia: available at http://www.electropedia.org

ISO 31000:2018
https://standards.iteh.ai/catalog/standards/sist/ae2e9e9b-4fd1-b678-1df56c39129d/iso-31000-2018

3.1
risk
effect of uncertainty on objectives

Note 1 to entry: An effect is a deviation from the expected. It can be positive, negative or both, and can address, create or result in opportunities and threats.

Note 2 to entry: Objectives can have different aspects and categories, and can be applied at different levels.

Note 3 to entry: Risk is usually expressed in terms of *risk sources* (3.4), potential *events* (3.5), their *consequences* (3.6) and their *likelihood* (3.7).

3.2
risk management
coordinated activities to direct and control an organization with regard to *risk* (3.1)

3.3
stakeholder
person or organization that can affect, be affected by, or perceive themselves to be affected by a decision or activity

Note 1 to entry: The term “interested party” can be used as an alternative to “stakeholder”.

3.4
risk source
element which alone or in combination has the potential to give rise to *risk* (3.1)

© ISO 2018 – All rights reserved

3.5
event
occurrence or change of a particular set of circumstances

Note 1 to entry: An event can have one or more occurrences, and can have several causes and several *consequences* (3.6).

Note 2 to entry: An event can also be something that is expected which does not happen, or something that is not expected which does happen.

Note 3 to entry: An event can be a risk source.

3.6
consequence
outcome of an *event* (3.5) affecting objectives

Note 1 to entry: A consequence can be certain or uncertain and can have positive or negative direct or indirect effects on objectives.

Note 2 to entry: Consequences can be expressed qualitatively or quantitatively.

Note 3 to entry: Any consequence can escalate through cascading and cumulative effects.

3.7
likelihood
chance of something happening

iTeh STANDARD PREVIEW
(standards.iteh.ai)

Note 1 to entry: In *risk management* (3.2) terminology, the word "likelihood" is used to refer to the chance of something happening, whether defined, measured or determined objectively or subjectively, qualitatively or quantitatively, and described using general terms or mathematically (such as a probability or a frequency over a given time period).

ISO 31000:2018
https://standards.iteh.ai/catalog/standards/sist/ddc2b9d2-1e30-4d11-bb78-1db56c391259/iso-31000-2018

Note 2 to entry: The English term "likelihood" does not have a direct equivalent in some languages; instead, the equivalent of the term "probability" is often used. However, in English, "probability" is often narrowly interpreted as a mathematical term. Therefore, in risk management terminology, "likelihood" is used with the intent that it should have the same broad interpretation as the term "probability" has in many languages other than English.

3.8
control
measure that maintains and/or modifies *risk* (3.1)

Note 1 to entry: Controls include, but are not limited to, any process, policy, device, practice, or other conditions and/or actions which maintain and/or modify risk.

Note 2 to entry: Controls may not always exert the intended or assumed modifying effect.

4 Principles

The purpose of risk management is the creation and protection of value. It improves performance, encourages innovation and supports the achievement of objectives.

The principles outlined in Figure 2 provide guidance on the characteristics of effective and efficient risk management, communicating its value and explaining its intention and purpose. The principles are the foundation for managing risk and should be considered when establishing the organization's risk management framework and processes. These principles should enable an organization to manage the effects of uncertainty on its objectives.

 © ISO 2018 – All rights reserved